

P02 internal remediation round 2

Status: internal remediation and local validation complete. Exact final-head CI and external review are recorded separately; no additional Copilot request authorized or made. Baseline: 5a59d8a5edcf78be56c969f15aea8afcf9afa3d, PR #855. Review: 5288422597, eight inline findings plus body observations.

Contract and scope

The sensitive values are the device draw, roll sequence/digest and derived mnemonic. During an active dice ceremony, including before setup is armed, DebugLinkState returns no fields: bytes, word encodings, canvas pixels and stored-secret aliases are all covered. Debug memory reads are refused too. On-device words and digest remain available for offline verification. Abort and commit wipe transient secrets and the old display before releasing the gate. After completion DebugLink resumes its privileged stored-wallet diagnostics; this is a ceremony privacy boundary, not a claim that a debug build protects a committed wallet from its diagnostic host. Shipping debug exclusion is checked separately. BOTH full and Bitcoin-only variants are in scope.

Necessary harness scope change: the pinned python-keepkey tests previously read forbidden device words and digest to build their oracle. Update that dependency on a dedicated published branch, retain legacy behavior for older candidates, and select the strict profile with KK_DICE_DEBUG_PRIVATE=1. Do not weaken or skip required wire execution. In the strict profile private dice screenshots are unavailable by design; native known-draw fixtures verify the device-side logical word pages and the complete reset derivation. Physical display review remains a release qualification. The host test independently verifies ONLY from injected rolls and the committed mnemonic; it cannot independently recover the MIXED device draw. The native fixture is required for that claim.

Findings inventory

Finding	Required disposition/evidence	Status
4080313772 + MIXED body note	Whole-state dice gate, getters, phase wire checks, independent derivation fixture, abort/restart	Fixed; native and wire checks pass
4080313826 Binance	Real initial and continuation renewal; malformed/polling expiry	Focused tests pass
4080313868 Cosmos	Same	Focused tests pass
4080313908 Mayachain	Same	Focused tests pass
4080313951 Osmosis	Same	Focused tests pass
4080313992 Tendermint	No generic wire map exists; incoming generic request rejection/expiry tested; no protocol activation	Technically declined: no wire map; explicit map/expiry assertions pass
4080314042 Thorchain	Real initial and continuation renewal; malformed/polling expiry	Focused tests pass
4080314092 reset	Renewal is at initial EntropyRequest, not EntropyAck; test actual reset dispatch at expiry	Focused test passes
EOS body note	Actual EosSignTx renewal plus existing chunk/empty-chunk tests	Focused tests pass
USB callback body note	Production callback source compiled with endpoint mock: short, complete, zero, error, buffer wipe, both endpoints	Focused tests pass
DebugLink latch body note	Clear rejection scope around normal debug dispatch, retain protected-wait rejection	Focused test passes
Wording body notes	Protected-wait message and precise disclosure contract; obsolete readiness claims superseded	Fixed

All eight inline findings and six body observations have local dispositions. GitHub thread closure follows the pushed code/evidence; it is not a fresh review.

Predecessor refresh during this round

Live Stack 01 advanced from 23b3c16b1 to 6b923be9993edfa7b072c56e87626374ba030f75 (commits 8952feb39 and 6b923be99). Reconcile storage downgrade refusal at setup commit and dispatch, v2 metadata native-value approval/reset, order-independent RNG fixtures, compose build failure propagation, Zcash native execution and explicit privacy-OFF build support. Existing P02 Hive/Zcash registration and stronger timeout regressions are retained where predecessor formatting patches conflict. Remove the P02 unconditional duplicate zcash.c source so privacy-OFF actually excludes it.

Do not import the predecessor's Ripple memo refusal removal: this P02 candidate still declares ripple-memo-policy unavailable and retains the existing refusal contract. Do not replace the report with the predecessor's receipt. Apply its Zcash full-product native-report requirement and additionally require the dice native and wire assertions introduced here. This is an assessed reconciliation, not acceptance or a rewrite of the shared predecessor/release branches.

Host harness pin: ea385cf6fdd5c22e2c3ea3845787777fb9c9d127, published at keepkey/python-keepkey, branch audit/p02-dice-debug-privacy-20260923.

1. Identity and frozen scope

Owner: Codex /root, workspace keepkey-vault-v11-agent-1. Isolated worktree: /private/tmp/kk715-p02-requalification-20260923, branch audit/p02-review-readiness-20260923. Code-bearing review: <https://github.com/BitHighlander/keepkey-firmware/pull/855>. Base: release/715-stack-02-chains at 51411c4a7c96137bc80f8b99fa1690c4e385f7fd. Frozen code/test/pin/workflow head: 947f5c29ab0b9a94baa44b33507bddcb0e13e449. The final formatting-only commit changes no firmware behavior. Native evidence covers its implementation and assertions; final exact-head hosted CI is a separate receipt. Inventory predecessor: 6f06021160b4cc97e29621042f2f508d324b44bc. The containing report head is in the PR body. The shared release branch is unchanged; accepted predecessor/release gates remain open.

Canonical SOP SHA256: fc343f5728e7f2c2057f416b9a16f962d1e31509c5c4faacb1cc12338fbc155. Canonical template SHA256 at report generation: ec9054a1612c5a9eca386eabda656b59bcd21d5c4a6f71460e55b98e70a36398.

Dependency	Exact committed pin
code-signing-keys	a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c
deps/device-protocol	dd9c85dc747cf965fb0e7bf49615dc9e7568ee65
deps/googletest	7888184f28509dba839e3683409443e0b5bb8948
deps/python-keepkey	ea385cf6fdd5c22e2c3ea3845787777fb9c9d127
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

The seven direct gitlinks match their local checkouts and committed public URLs. Unused nested vendor checkouts remain uninitialized and are listed explicitly in round2-submodules.txt. CI must independently fetch the committed dependencies.

2. Git line inventory and plain-language changes

The companion P02-ROUND2-COMMIT-INVENTORY-20260923.md inventories every commit through the frozen code head: SHA, title, every changed path and numstat. Earlier receipts retain historical test identities; their privacy closure is superseded. The net table below is the immutable adjacent review range, including report files once present in the inventory predecessor. Do not sum overlapping commits.

Change group	Prior behavior / new behavior	Verification
SOP and template	Field-level checks could stand in for confidentiality; now value/observer/phase/output and falsification evidence are required	Canonical SOP/template changed; receipt follows their matrix
Dice privacy	Raw bytes hidden but words, digest and canvas exposed; now whole-state and memory-read gate until cleanup	Six native fixtures, full host ceremonies, page cancellation, getter/canvas/gate mutations
Timer coverage	Several hooks untested; actual reachable initial/continuation dispatch tested near expiry	Five chains plus reset/EOS, malformed and polling cases; 13 removed-hook mutations detected

Change group	Prior behavior / new behavior	Verification
Dormant Tendermint	Compiled handler was mistaken for a registered protocol	Initial/ACK/request map absence and incoming-request expiry assertions; no new protocol enabled
USB receive / latch	Only helper tests; debug normal dispatch retained stale rejection	Production callbacks shared with endpoint probe; full/short/empty/error/scrubbing; latch regression
Predecessor	New reviewed storage/approval/build fixes missing from local baseline	Assessed 6b923be99 delta; storage non-write test, native/host/ARM reruns, explicit Zcash-OFF build
Harness / report	MIXED oracle read forbidden words; report counts did not require privacy assertions	Public host pin; known-draw native oracle; nine omission controls rejected by report gate

Added	Deleted	Path
12	4	.github/workflows/ci.yml
8	0	.gitleaks.toml
13	3	CMakeLists.txt
1	1	deps/python-keepkey
12	1	docs/DiceEntropy.md
39	0	docs/release/REHEARSAL-SOP.md
445	0	docs/release/audit-units/715-01-review-20260923.md
-	-	docs/release/audit-units/715-01-review-20260923.pdf
275	0	docs/release/audit-units/P02-INTERNAL-ROUND2-20260923.md
-	-	docs/release/audit-units/P02-INTERNAL-ROUND2-20260923.pdf
42	0	docs/release/audit-units/P02-PR-PREFLIGHT-20260923.md
83	0	docs/release/audit-units/P02-RETROSPECTIVE-20260923.md
1195	0	docs/release/audit-units/P02-ROUND2-ARTIFACTS-20260923.json
377	0	docs/release/audit-units/P02-ROUND2-COMMIT-INVENTORY-20260923.md
4120	0	docs/release/audit-units/P02-ROUND2-SKIPS-20260923.json
780	0	docs/release/audit-units/P02-readiness-20260923-artifacts.json
3033	0	docs/release/audit-units/P02-readiness-20260923-skips.json
295	0	docs/release/audit-units/P02-readiness-20260923.md
-	-	docs/release/audit-units/P02-readiness-20260923.pdf
44	0	docs/release/audit-units/P02-readiness-manifest-20260923.md
36	0	docs/release/audit-units/P02-requalification-20260923-artifacts.json
251	0	docs/release/audit-units/P02-requalification-20260923.md
-	-	docs/release/audit-units/P02-requalification-20260923.pdf
20	11	docs/security/7.14.3-bitcoin-only-dice-audit-sop.md
8	0	include/keepkey/board/messages.h
3	1	include/keepkey/firmware/reset.h
2	0	include/keepkey/rand/rng_health.h
5	1	lib/board/confirm_sm.c
38	1	lib/board/messages.c
2	0	lib/board/udp.c
8	47	lib/board/usb.c
56	0	lib/board/usb_rx_callbacks.h
0	2	lib/firmware/CMakeLists.txt
28	4	lib/firmware/ethereum.c
34	13	lib/firmware/fsm.c
2	0	lib/firmware/fsm_msg_binance.h
10	0	lib/firmware/fsm_msg_common.h
2	0	lib/firmware/fsm_msg_cosmos.h
16	1	lib/firmware/fsm_msg_debug.h
6	0	lib/firmware/fsm_msg_eos.h
2	0	lib/firmware/fsm_msg_mayachain.h
2	0	lib/firmware/fsm_msg_osmosis.h
2	0	lib/firmware/fsm_msg_tendermint.h
2	0	lib/firmware/fsm_msg_thorchain.h
8	0	lib/firmware/passphrase_sm.c
3	0	lib/firmware/pin_sm.c
2	0	lib/firmware/recovery_cipher.c
38	19	lib/firmware/reset.c
2	0	lib/firmware/signed_metadata.c
19	13	lib/firmware/signing.c
5	0	lib/rand/rng_health.c
5	1	scripts/emulator/python-keepkey-tests.sh
10	1	scripts/generate-test-report.py
15	0	unittests/board/board.cpp
2	0	unittests/firmware/CMakeLists.txt
823	21	unittests/firmware/fsm.cpp
8	0	unittests/firmware/recovery.cpp
97	0	unittests/firmware/reset_policy_probe.c
2	3	unittests/firmware/rng_health.cpp
20	6	unittests/firmware/signed_metadata.cpp
22	0	unittests/firmware/storage_passphrase.cpp
72	0	unittests/firmware/usb_callbacks.cpp

3. Current-source reconciliation and findings

The finding table above accounts for all inline and body-only observations. No finding is closed by test totals alone. Source review followed the device draw through raw bytes, BIP-39 words, roll digest, backup mnemonic and canvas. The observer is a host on normal/debug protocol endpoints; the local native fixture and emulator process owner are trusted test infrastructure. The on-device user is allowed to see the verification material.

Phase / boundary	Assertion / executed evidence
Consent and MIXED word subpages	Complete DebugLinkState has no fields; wire page cancellation test reaches the previously missed phase
Dice entry and digest	Strict host driver observes empty state before/after input; native getters reject raw/word/digest output
EntropyRequest and backup	Empty state persists through EntropyAck and every backup prompt; known fixture checks correct device-side words and commit
Abort/restart	Native cancellation at six phases; transient buffers and canvas wiped; ordinary reset diagnostics restored
Derivation	Native independent SHA-256 vectors for MIXED/ONLY at 128/256 bits; wire ONLY assertion against injected rolls; existing 75-roll helper test covers 192-bit count, not a complete 192-bit dice ceremony
Debug memory reads	Active-dice dump refused; native assertion distinguishes this from generic emulator refusal
Production variants	ARM debug OFF; debug handlers/transport and native probe symbols absent; separately verified from diagnostic-build privacy

Falsification controls: all 13 removed renewal hooks fail their targeted tests; raw, word, digest and canvas guard removals fail native fixtures; removed short rejections fail both production callback probes; removing whole-state redaction makes all three selected host privacy tests fail. Removing each of nine required privacy results makes the report validator refuse the evidence. Mutation results are diagnostic controls on the unchanged P02 guards/hooks; predecessor refresh retains those implementations and repeats their positive suites.

Inherited limits remain: accepted predecessor status, physical USB transport and OLED behavior, physical RNG guarantees, signed-device upgrade/downgrade and power interruption qualification. Historical F161/F204 limitations and the staged capability ledger are not waived. Ripple memo support remains excluded. No claim is made that DebugLink protects a committed wallet from its privileged host or that a native logical-page check proves physical OLED rendering.

4. Verification and artifact identity

Builder: kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. Host runner: sha256:a59cfc6b8bafb34ae3dce21865240013b4a370d7b15d8ea09f42b0814874a82a. Source mounted read-only; test outputs isolated; test containers used no network. Commands, failures during fixture development, passing final runs and negative controls are retained under /private/tmp/kk715-p02-audit-evidence/round2-*. Authoritative completed integration files use the round2-reconciled- prefix; full native uses round2-frozen-full-xunit.log, BTC round2-final-btc-xunit.log.

Observed suite	Result
full-final-host	{'passed': 581, 'skipped': 257}
full-screenshots	{'passed': 68, 'skipped': 19}
full-firmware	453
full-board	20
full-crypto	18
full-zcash-crypto	72
btc-final-host	{'passed': 352, 'skipped': 486}
btc-screenshots	{'passed': 27, 'skipped': 60}
btc-firmware	148
btc-board	20

Observed suite	Result
btc-crypto	18

Both screenshot audits pass: full 402 PNGs / 68 sequences; BTC 177 PNGs / 27 sequences. Dice secrets are deliberately not captured through DebugLink. Exact skipped test names and reasons are in P02-ROUND2-SKIPS-20260923.json. No skipped test is reported as a pass. The capability-gate environment can be changed by existing harness tests; counts above describe actual XML results.

ARM SRAM gates pass: full reserve 18,308 B, BTC reserve 32,340 B; largest frame 7,664 B. Explicit full Zcash-OFF build passes 35 focused workflow/privacy/map checks. Native full additionally executes 72 Zcash crypto tests under xunit. Formatting passes on every changed C/C++ path; git diff --check passes; code secret scan passes. The artifact manifest has 233 SHA256-bound entries, including logs, XML, native/ARM binaries and screenshot sequence manifests.

5. Report render and local preflight

Source and PDF share this receipt. Per-commit inventory and skip/artifact JSON are companion evidence. Rendered pages are inspected before final preflight. Run the canonical check-code-review-diff.sh against the recorded base and final head; bind the final head, live base, artifact verification and render result in the PR body/post-freeze receipt. Documentation-only sealing commits do not change runtime behavior. Exact final-head CI must be reported as pending until delivered.

6. Copilot checkpoint and completion

One authorized request was consumed: timeline event 31659436735; review 5288422597 on 5a59d8a5edcf78be56c969f15aea8afcf9d9afa3d, effort Lite, eight inline findings plus body notes. Internal remediation is complete at this code head. Replies/resolutions record evidence or the dormant-protocol rationale. A resolved backlog does not mean Copilot reviewed this new head. A second request requires fresh owner authorization and is not made by this round. Recommended next external effort: Balanced, without changing repository settings. Release acceptance, upstream publication and shared branch restacking remain separate.